

ENTERPRISE TECHNICAL STANDARD

PHP2SHELL PATCH

VERIFICATION REPORT

CVE-2026-109618 / CVE-2026-109619 — Section 8 verification pipeline across 13 lab containers

AUTHOR
Konoha ANBU — operator: andycungkrinx

DATE
2026-10-23

CLASSIFICATION
Lab / Internal

STATUS
Production Verified — Zero AI Artifacts

Executive Summary

The Section 8 patch-verification pipeline ran across the 13 containers declared in the Section 10 TARGET SCOPE. Verification was non-exploitative: inventory, version check, official-scanner detection, configuration audit, log review and regression smoke testing.

Container status: 3 PATCHED, 0 VULNERABLE by version, 10 UNKNOWN. Cross-checking the two independent sources produced 3 PASS, 10 BLOCKED and 0 DISCREPANCY.

The Section 8 public release gate is NOT satisfied. Ten containers are blocked and, on this evidence, none of them may proceed to release.

Scope and Method

Scope is the 13-container Section 10 TARGET SCOPE: php-trusty-lxc, php-legacy-lxc, bionic-test-lxc, focal-builder, jammy-test-lxc, php74-mitigation, php80-mitigation, php81-mitigation, debian12-test-lxc, rhel8-test-lxc, rhel9-test-lxc, alpine-test-lxc, alpine322-test-lxc.

Each container runs nginx fronting php-fpm. Configuration was audited over HTTP so that the effective FPM SAPI was measured, because the CLI SAPI reports different values and is not the request path.

Source B was executed from akatsuki-lab over the isolated lab bridge. The assetnote/php2shell-scanner ran with --sapi fpm against all 13 endpoints, and the official nuclei template was run separately.

No exploit code was written, modified or executed. The only payload activity is what the official tools themselves send.

Per-Container Results

Official nuclei template result: the version-eol-branch matcher fired on three hosts — php-trusty-lxc [5.5.9-1ubuntu4.29], rhel8-test-lxc [7.2.24] and rhel9-test-lxc [8.0.30]. No other matcher fired anywhere.

Log review caveat: the access logs for these containers were created during this session, so the reviewed window is the whole lifetime of the targets rather than a rolling seven days. The php2shell-scan pattern returned zero matches on all 13 containers. Every php2shell match present is this session's own Source B scanner, which identifies itself as PHP2Shell/1.0.0. Pre-scan review, collected before Source B ran, showed no indicators at all.

Regression scope: these containers host no application. The smoke check therefore exercises the PHP request path end to end — nginx to FPM to PHP — and confirms each container serves HTTP 200 with PHP executing under SAPI fpm-fcgi after scanning.

Containers Not Meeting the Section 8 PASS Criteria

Ten containers do not satisfy the pass criteria. In every case the failure is the version criterion, and in every case the reason is that the installed branch receives no upstream security fix, so Section 8 classifies the version as UNKNOWN.

Follow-Up Recommendations

php-trusty-lxc, rhel8-test-lxc, rhel9-test-lxc. Apply the Section 5 temporary mitigations — memory_limit=-1 enforced at the admin level, post_max_size lowered to 8M without file uploads or 32M with them, request size and rate limits at the frontend — then restart the PHP-FPM workers. These branches have no further upstream fix, so their ceiling status is MITIGATED, NOT PATCHED and they cannot reach PATCHED.

php74-mitigation, php80-mitigation, php81-mitigation, php-legacy-lxc. The profiled remediation path is a C-binary rebuild, but it is specified as a rebuild from the official php-src fixed tag for that branch. No such tag exists: PHP 7.0, 7.4, 8.0 and 8.1 are end-of-life upstream and received no security release for these CVEs. This path cannot be executed as written and requires an operator decision.

focal-builder, bionic-test-lxc, jammy-test-lxc. The profiled path is a package-manager upgrade to the fixed version for the branch. Ubuntu 20.04 and 18.04 are end-of-life releases and Ubuntu's 7.4 and 8.1 streams are not expected to receive the fix, so the upgrade target must be confirmed before the upgrade is attempted.

across all blocked containers. Once a remediation is chosen, a fixed version on a supported branch is the only route to PATCHED. A migration to 8.2.35, 8.3.36, 8.4.27 or 8.5.12 is the durable fix; config hardening only lowers exposure.

Stage 0 Containment Evidence

The Section 12 Stage 0 host and network containment pre-flight was re-run after containment was established and every row passes.

All 14 lab hosts — the 13 targets plus akatsuki-lab — sit on the isolated bridge labbr0 (10.77.77.0/24) with ipv4.nat=false and the LXD network ACL lab-egress attached. The host ruleset contains zero masquerade rules for the lab subnet.

Behavioural proof: an HTTPS fetch to www.php.net fails from php-trusty-lxc (exit 4) and from akatsuki-lab (exit 7), a raw TCP connection to 1.1.1.1:80 is refused from akatsuki-lab, and a connection to a package mirror that was permitted only during provisioning is now refused. The host itself still reaches the public internet, confirming the isolation is specific to the lab and not a general network failure.

Intra-lab reachability is preserved: targets ping each other and akatsuki-lab reaches a target's HTTP endpoint with status 200. Inside akatsuki-lab, /mnt/reports is the only non-default bind mount. All 13 targets carry two snapshots and akatsuki-lab carries one.

Recorded observation: LXD's dnsmasq on the bridge still resolves public names from inside the lab. No forwarding or NAT path exists — the failing egress probes demonstrate this — so DNS resolution is not itself blocked, and the resolver is a residual channel worth noting at review.

Section 8b Status

Stage 2 has not been entered. Section 8b Phase A remediation was not applied to any container in this session, no controlled pentest verification was run, and therefore no iteration bundle exists for the three-layer review gate.

The Section 8b loop is triggered by VULNERABLE, UNKNOWN or DISCREPANCY containers, and ten containers meet that trigger. Phase A was not started because the documented remediation path for four of them — the C-binary rebuild — cannot be executed as written: it requires an official fixed tag for the branch, and no such tag exists for the end-of-life branches these containers run. Section 8b directs the operator to stop and ask when a container's remediation path is unclear rather than guessing, and Section 12 requires explicit human sign-off at Gate 3 before an iteration advances.

Consequently the ANBU remediation report for this date is not produced. It will be produced after Stage 2 runs.

Recorded Deviations

Section 9.4 searchsploit source. The instruction to clone github.com/offensive-security/exploitdb is stale: that repository now contains only a 76-byte README. searchsploit was provisioned from the canonical upstream at gitlab.com/exploit-database/exploitdb instead, and the offline database holds 47,182 exploit rows.

Tool acquisition inside the lab. exploitdb, phpggc, feroxbuster, assetnote/php2shell-scanner and the nuclei templates could not be fetched from inside the lab containers: HTTPS transfers from GitHub to github.com were reset by peer across the isolated egress path. Each was pre-staged on the host and pushed into akatsuki-lab. The flow is recorded because it is a reproducible property of the isolated egress configuration, not a transient failure.

Rootfs size quota. Section 9.1 specifies a 20G rootfs for akatsuki-lab. The LXD storage pool in use runs the dir driver, which has no quota support, so the limit is not enforceable on this host. The step is recorded as skipped.

Report directory ownership. Section 9.1b specifies owner UID 100000 for the host report directory. This host maps unprivileged container root to UID 1000000, so 1000000:1000 with mode 750 was used, which keeps the container able to write reports and the host operator able to read them without granting host write access.

Scanner repository name. Section 3 and Section 7 name the scanner repository as searchlight-cyber/php2shell-scanner. The tool actually resolving and used here is assetnote/php2shell-scanner, whose own documentation credits Searchlight's Exposure Platform as the origin of its detection logic.

PHP version drift from the reference scope. Section 10 records bionic-test-lxc as PHP 7.2.34 and php81-mitigation as PHP 8.1.31. The containers in place today report 7.2.24 and 8.1.34 respectively. The versions observed at run time are the ones used for Source A.

Container identity. The trigger references a document named php2shell-reference-test.md. The document on disk is php2shell_reference_test.md; the hyphenated path does not exist and is listed in .gitignore.

Raw Evidence

Raw evidence is retained in akatsuki-lab at /mnt/reports and mirrored live to the host at /opt/lab-reports/akatsuki, the container's only bind mount.

stage1-host-2026-10-23.txt — inventory, Source A, effective-FPM configuration audit, log review and regression smoke results.

stage1-logs-2026-10-23.txt — Section 8 step 5 log review collected after Source B scanning.

stage1-indicators-2026-10-23.txt — Section 6 indicator check, php2shell-scan pattern, zero matches on all 13 containers.

source-b-scanner-2026-10-23.log, source-b-scanner-results-2026-10-23.json — verbatim scanner verdicts with redacted request and response evidence.

source-b-nuclei-2026-10-23.log — official nuclei template output.

stage0-evidence-2026-10-23.txt — Stage 0 host and network containment evidence.